RESEARCH-DRIVEN ROADMAP · PHASES E–H

RED-AGENTIC-TEAMS

What the offensive engines still need, and what must become generic: ten capability gaps, eight generalization contracts, and four phases — every item traced to a verified research verdict and an executed run artifact.

Phase A–D **executed and verified**
Phase E–H planned
2026-11-04

RESEARCH FIRST · CODE SECOND

Table of Contents

1. Method and Evidence Contract 2

2. Verified Baseline - Where the Program Stands 2

3. Gap Register - What the Tools Still Need 3

4. Generalization Matrix - What Must Become Generic 6

5. Phases E-H 7

6. Rejected Directions 8

7. Research Traceability 8

8. Metrics and Reporting Contract 9

1. Method and Evidence Contract

This roadmap answers two questions asked of the program: **what do the tools still need**, and **what must be made generic**. It is derived the same way every artifact in this program was built - research first, code second, numbers from executed runs only. Three evidence classes are used, and every roadmap item cites at least one of them.

External research verdicts. The Phase A dossier and the two pre-build digests: *swarm-specialists/RESEARCH.md* (mechanisms M1-M8, improvement loop E1-E6, anti-patterns A1-A3) and *hard-lab/RESEARCH.md* (design rationale R1-R6). Each verdict carries an [F] flag (source fetched and read) or [H] (secondary signal); [U] items appear only as labeled assumptions. **Executed results.** Run artifacts under statefuzz-prototype, swarm-specialists, fortress-lab and hard-lab: findings.json, traffic.jsonl, hypothesis_ledger.json, score.json and report.md. Every number in Chapter 2 comes from opening those files. **A code audit run on 2026-11-04.** Copy divergence, a target-literal census across engine packages, seam inventory, and memory and ledger API inspection; every "today" claim in Chapter 4 cites file and line from that audit.

Item states are honest: **D0** not started, **D1** designed with its acceptance test written, **D2** done and measured. Nothing in Chapters 3-5 is claimed done before its acceptance test is green. This is the same [F]/[H]/[U] discipline the program has used since the Phase A dossier, applied to planning instead of research.

2. Verified Baseline - Where the Program Stands

0/10 → 10/10	7/8 · 0 FP	23 hypotheses
fortress baseline vs swarm v0.2 after generalizing	hard-lab seeds found, false positives on decoys	full believe-test-resolve ledger lifecycle

Phases A through D are executed, and every claim below is backed by an artifact in the repository. Phase B built the state-machine fuzzer and proved it on dvlba-shop; the v1 rewrite then measured oracle precision itself - zero findings on the fixed build over the same 37 mutants. Phase C wrapped the tool in a seven-specialist swarm with typed blackboard, bandit routing and persisted memory, and showed the second run getting measurably leaner. Phase D attacked two deliberately hard labs: helios-billing, where the unmodified Phase B tool scored zero out of ten before the swarm upgrade, and meridian-vault, which removed openapi disclosure entirely and connected both engines to the unified HypothesisLedger.

Phase	Artifact	Target	Executed result	Tests
A	Research dossier (PDF)	-	12+ systems surveyed and compared; academic gap confirmed: no published work combines LLM-inferred FSM + metamorphic invariant oracles + illegal-transition mutation + concurrency injection	-
B	statefuzz-prototype	dvlba-shop	8/8 seed classes found in 87 requests / 1.0 s; 3 chains (2 critical); all 5 invariant classes triggered	25
B+	statefuzz (v1 rewrite, 1,921 ln)	vuln-bank (in-process)	19 findings covering all 5 invariant classes; 0 findings on the fixed build over the same 37 mutants - oracle precision measured	59
C	swarm-specialists	dvlba-shop	9 dedup findings (all 8 seed classes), 8 independently re-verified, 3 critical chains; exploit spawned statefuzz mid-run (exploit/statefuzz_spec provenance); run 2 leaner (188 to 181 requests) from persisted memory	13
D-1	fortress-lab (helios-billing)	10 seeds, fresh domain	as-shipped statefuzz: 0/10, 73 requests, every probe a 404; swarm v0.2 after 4 real defects fixed: 10/10 (329 req run 1, 322 req run 2)	12
D-2	hard-lab (meridian-vault)	8 seeds, 4 decoys, no openapi	swarm: 7/8 seeds, 0 false positives (303/304 requests); statefuzz standalone: 0 findings / 64 requests - the measured generalization gap; ledger: 23 hypotheses (12 confirmed, 2 by-transcript, 3 refuted, 4 inconclusive), score 16.5	13

Table 1 - Executed results per phase, quoted from run artifacts.

The baseline proves two things at once. The swarm loop - hypothesis, technique, verification - generalizes across two shifted domains, the ledger lifecycle works, and memory persists and pays. At the same time, the engines still carry their birthplace with them: the shipped Phase B tool scores 0/10 the moment target vocabulary changes, and the swarm package that solved both labs still contains roughly 135 target-specific literals. Resolving that tension is exactly what Phases E through H do.

3. Gap Register - What the Tools Still Need

Ten capability gaps, each with the evidence that exposes it, the capability to build, and the acceptance test that will mark it done. Each item states its current status; all begin at D0.

G1 - Hint-free surface discovery and the missing enumeration arm · D0

Evidence: hard-lab S8 (403-vs-404 account existence oracle) was missed by both runs - no engine technique probes status-code differentials. Upgrades U1-U3 removed the openapi dependency, but a target with neither openapi nor a route index would still starve recon (the central tension, hard-lab RESEARCH.md R1). **Research:** Kettle probe-for-clues methodology [F]; OWASP API1 BOLA [F].

Capability: a new h_oracle_enum arm - parameter-object enumeration by status-code differential (403/404/200), severity capped LOW - plus a hint-free recon fallback using verb wordlists per discovered resource. **Acceptance:** meridian-vault re-run reports S8 as a LOW finding, decoys stay at 0 false positives,

request budget grows at most 15 percent over the 303-request baseline.

G2 - One engine, four copies · D0

Evidence: four statefuzz copies exist. The top-level v1 rewrite (1,921 lines) is generic; three lineage forks (~1,131-1,193 lines) are byte-identical except executor.py (hard-lab adds race_multi at lines 151-204) and registry_tool.py (unfamiliar-surface guards at lines 342/347). Two swarm copies fork the same way; hard-lab is the strict superset. Fixes do not propagate. **Capability:** one installable package - v1 as base, porting race_multi, header capture and the guards; swarm imported from the superset. **Acceptance:** labs run against the package, not vendored copies; a grep for WELCOME10, ONCE-9K4T or dvlba over the package returns zero; all four suites (59 + 13 + 12 + 13 tests) green from one checkout.

G3 - Target vocabulary out of the engine · D0

Evidence: the lineage statefuzz carries ~120 target literals (registry_tool alone: 80, e.g. the ONCE-9K4T coupon race probe); each swarm copy carries ~135 (exploit 49, verify 39, surface_mapper 19, techniques 16) - checkout endpoints, auth paths and recon probe lists are constants. Only the v1 rewrite and engine/ledger.py are clean. **Capability:** endpoint templates resolved from the resource graph plus a target profile; the pattern already exists in techniques.py line 746, templated except the /api prefix. **Acceptance:** fortress 10/10 and hard-lab 7/8 reproduced with zero endpoint literals in engine modules (CI grep); vocabulary lives only in profile files.

G4 - LLM seam: wired but decorative · D0

Evidence: LLMSeam (47 lines, byte-identical in both swarm copies) has two call sites; generate_hypotheses returns None without a backend and no harness passes llm_backend anywhere; tie_break logs the backend call but still returns the first choice (llm.py lines 41-47). **Research:** E6 [H] - never route on self-reported confidence; LLM output enters the board as a hypothesis with a prior, tested before it becomes a finding. **Capability:** a real backend behind the seam; tie_break actually consuming the ranking; the hypothesis prompt carrying surface facts and the prior schema; malformed output falling back to deterministic rules. **Acceptance:** a fake-backend test proves an LLM hypothesis cannot become a finding without execution evidence; an A/B run on hard-lab reports hypotheses-per-request and lead-to-hit rate with decoy false positives staying at zero.

G5 - Memory is not target-scoped · D0

Evidence: MemoryNamespace persists one JSON per specialist keyed by specialist name only (memory.py line 22); the poisoning guard caps target-derived outcomes at weight 0.25, but any run sharing a memory_dir inherits the previous target's bandit posteriors wholesale. record() persists nothing mid-run - only end-of-run curate() saves. Anti-pattern A3 predicted exactly this. **Capability:** two-layer memory - per-target bandits (namespace = target id + specialist) plus a global store holding only target-agnostic insights (the rejection gate already exists at memory.py lines 76-78), with top-N pruning. **Acceptance:** a test proves target B cannot inherit target A's posteriors; a grep over the global store for target nouns returns zero; the run-2-leaner effect is preserved within a target.

G6 - Two ledgers, one bridge · D0

Evidence: the unified ledger (engine/ledger.py: propose, attach, resolve, deferred; honest statuses; refuted scores 1.0 because refuting a belief with evidence is a result) coexists with the older Phase B ledger inside statefuzz (oracle.py lines 23-50, whose verify hardcodes wallet semantics); they are bridged only in the runner (run_hardlab.py lines 234-254). **Capability:** a single ledger service; statefuzz deferred windows project onto it through a small adapter; expectation callbacks replace wallet arguments. **Acceptance:** one hypothesis_ledger.json per run containing swarm, statefuzz and runner entries; the oracle ledger retired.

G7 - Race transport: loopback-only realism · D0

Evidence: race_multi does last-byte sync over HTTP/1.1 on loopback (executor.py lines 151-204); both labs widen race windows application-side and say so honestly (RESEARCH.md R5). **Research:** the single-packet attack [F] is the production primitive; the v1 README already commits to swapping the adapter with the executor interface unchanged. **Capability:** a transport abstraction behind timing="race" - loopback barrier versus single-packet implementation - plus window telemetry (measured inter-response deltas) stamped into race findings. **Acceptance:** the same quota-race finding reproduces under a jitter-simulated test on both transports; race findings carry the measured window, not just a transcript.

G8 - Verification independence · D0

Evidence: the verify specialist re-runs the same technique library in-process with fresh principals; hard-lab re-verified 7 findings and honestly downgraded the consumed race artifact - but verifier and finder share a code path, so a library bug would correlate across both. **Research:** E3 [F] Huang - reflection is only valid grounded in external evidence; M6 [F] Voyager - verify before promote. **Capability:** an out-of-process prover replaying each finding from findings.json alone (preconditions + grants), fresh principal, separate process and HTTP session. **Acceptance:** at least 90 percent of findings re-verified by the independent prover on both labs; a seeded library-bug test shows the prover flags the mismatch instead of confirming it.

G9 - Cost and eval accounting - the GEPA precondition · D0

Evidence: request counts and ledger scores exist per run, but no single scorer computes a comparable metric pack across the three labs, and there is no eval corpus - exactly what GEPA-style evolution requires (E2 [F], deliberately deferred). **Capability:** one scorer over run artifacts producing discovery rate, false-positive rate, requests-per-verified-finding and ledger score; the eval corpus is the union of all three lab seed sets; specialist heuristics stay swappable strategy objects. **Acceptance:** the scorer reproduces every number in the three existing reports from their artifacts; a dry-run evolution loop samples trajectories and rewards with no code changes.

G10 - Auth and identity lifecycle modeling · D0

Evidence: the technique library hardcodes register and login paths (techniques.py lines 120-123); principals are flat; the FSM model carries no roles, token refresh or privilege states - yet fortress F6 was only exploitable through a leaked identity, and OWASP API1/API3 is exactly object and role level authorization. **Capability:** an auth recipe in the profile; role-aware principals; FSM nodes annotated with role requirements; a new mutant family - privileged action attempted without the granting role. **Acceptance:** a role-gated seed in a fourth lab found by the role-confusion mutant with no target-specific code, existing lab

results unchanged.

4. Generalization Matrix - What Must Become Generic

The audit's central finding: the program already contains its own generic version of statefuzz - the top-level rewrite with parameterized invariant factories - while the engines actually exercised by the labs are the older, vocabulary-laden forks. The census below quantifies the duplication; the matrix then names the contract each component must satisfy to become generic, with today's evidence and the test that closes the gap.

Package copy	Lines	Target literals	Status
statefuzz/ (v1 rewrite)	1,921	1 (docstring)	generic base; missing registry glue parity
statefuzz-prototype/statefuzz/	1,131	120	lineage fork, least evolved
swarm-specialists/statefuzz/	1,189	120	lineage fork
hard-lab/statefuzz/	1,193	120	most evolved fork (race_multi, guards)
swarm-specialists/swarm/	2,550	134	fork
hard-lab/swarm/	2,757	136	strict superset (U1-U3)
hard-lab/engine/ledger.py	128	1 (docstring)	generic; to become the only ledger

Table 2 - Copy census, code audit of 2026-11-04.

Component	Today (evidence)	Generic contract	Acceptance test	Phase
M1 Engine packaging	4 statefuzz copies + 2 swarm copies; divergence concentrated in executor.py and registry_tool.py	One package; labs consume it as a dependency; vendored copies deleted	All suites green from one checkout	E
M2 Target profile	ONCE-9K4T at exploit.py:18; /api/checkout/init at exploit.py:131-135; promo_code artifact at registry_tool.py:218	Profile declares base URL, auth recipe, vocabulary map, money fields, engagement artifacts, disclosure tier	Third lab onboards with profile + seeds only, zero engine edits	E
M3 Invariant factories	v1 factories make_conservation(field_name=...) vs lineage constants cart_after.get("subtotal_cents") at hard-lab invariants.py:19-21	All I1-I5 observers take field names and mint/burn edges from the profile	Meridian invariants expressible in a ~10-line profile; 5 classes still trigger	E
M4 Technique de-vocabularization	~135 literals per swarm copy: exploit 49, verify 39, surface_mapper 19, techniques 16	Techniques consume the resource graph + profile; no endpoint strings; auth paths from profile	CI grep zero endpoint literals; both labs score as before (10/10, 7/8)	E
M5 Ledger unification	engine/ledger.py generic; oracle.py ledger wallet-hardcoded; bridge only in run_hardlab.py:234-254	One ledger service; statefuzz deferred windows project via adapter; expectation callbacks	Single hypothesis_ledger.json per run; oracle ledger retired	F

Component	Today (evidence)	Generic contract	Acceptance test	Phase
M6 Memory v2	key = specialist name only (memory.py:22); curate-only persistence; insight gate exists (memory.py:76-78)	Per-target bandits + global target-agnostic insight store; top-N pruning; explicit transfer policy	Cross-target inheritance test fails as it should; store grep for target nouns = 0	F
M7 LLM seam completion	generate_hypotheses falls back to None; tie_break ignores the backend (llm.py:41-47)	Pluggable backend; output validated as hypothesis-with-prior; tie_break consumes the ranking	Fake-backend contract test; A/B hard-lab run with decoys staying 0	G
M8 Race transport	last-byte sync on loopback (executor.py:151-204); windows widened app-side (R5)	Transport interface: loopback barrier and single-packet implementations; window telemetry in findings	Jitter-simulated test: same finding on both transports	F

Table 3 - Generalization matrix: evidence, contract, acceptance, phase.

5. Phases E-H

Sequencing rule: each phase leaves the honesty instrumentation untouched - loopback fail-closed scope guard, STOP kill file, request budgets, fresh-principal probes, provenance stamps, honest statuses - and its acceptance tests green before the next phase starts.

Phase	Focus	Work items	Exit criteria
E Consolidation	Make it one engine (M1-M4; G2, G3)	Merge forks into one package; introduce the target profile; port invariant factories; de-vocabulary the techniques	Third lab (new domain, hint-free tier) onboarded with profile + seeds only; all suites green from one checkout; CI literal grep = 0; fortress 10/10 and hard-lab 7/8 unchanged
F Spine	One ledger, scoped memory, honest races (M5, M6, M8; G1, G5-G7, G9)	Unify the ledger; memory v2; race transport abstraction with window telemetry; add h_oracle_enum; stand up the single scorer	One hypothesis_ledger.json per run; memory isolation proven by test; S8 found within +15% budget with decoys still 0; scorer reproduces all prior numbers
G Mind	A real model behind the seam (M7; G4, G8)	Wire a real LLM backend into the two seams under the E6 contract; complete tie_break; build the out-of-process prover	Hypothesis-with-prior contract tests pass; A/B shows no false-positive increase; at least 90% of findings re-verified independently; prover independence test passes
H Learning loop	Evolution with eval gates (E2; G9)	GEPA-style reflective evolution over specialist strategy objects against the eval corpus; measure cross-target transfer	Run 3 measurably leaner than run 2 at equal discovery; cross-target hit-rate delta measured with and without the global store; zero rewards from refuted outcomes

Table 4 - Phase work packages and exit criteria.

Phase E is deliberately first: it converts "works on our two labs" into "works on the next target", and every later phase depends on the single package and the profile abstraction. Phase F builds the connective spine - one ledger, scoped memory, honest race transport - so that Phase G can attach a real model without changing the evidence discipline, and Phase H can evolve prompts against a stable, scored corpus. The platform contract (scope guard, STOP file, fresh principals, provenance) is never a work item: it is invariant across all phases, and each phase's runs must pass it as before.

6. Rejected Directions

The roadmap excludes the following directions on research grounds, not on taste. Each exclusion names the source that rejects it, so a future revision must argue with the source, not with preference.

- **Ungrounded self-critique loops** - Huang et al. [F]: intrinsic self-correction without external feedback fails and can degrade; reflection runs only on execution evidence (E3).
- **Learning from attacker-controlled feedback** - target-controlled content may create hypotheses but may never promote techniques to learned (A2 poisoning guard; outcome weight 0.25).
- **Cross-target memory bleed** - insights must be target-agnostic or per-target namespaced, pruned to top-N (A3; closed by M6).
- **Routing on self-reported confidence** - verbalized confidence is weakly calibrated [H] (Tian et al.); routing uses trigger matches and posterior means only (E6).
- **LLM as adjudicator** - findings are candidate evidence; verification and severity sign-off belong to execution and the verify pipeline (statefuzz design limits).
- **Unbounded sub-specialist spawning** - depth at most 1, narrow tasks, own budgets, distilled outputs only (M4; Anthropic multi-agent [F]).
- **openapi as a load-bearing dependency** - fortress measured the cost: as-shipped probes scored 0/10 against a shifted domain; disclosure tiers (M2) replace dependence.
- **Hardcoded target constants** - the fortress engineering log is the existence proof: four defects, all rooted in vocabulary or shape assumptions, fixed by generalizing instead of hardcoding.

7. Research Traceability

Every roadmap item descends from a research verdict and an executed result. The table is the audit trail: if a mechanism is not listed, it is not in the build; if a verdict is listed without an item, the decision was to keep the existing implementation.

Verdict (source)	Executed evidence in this repo	Roadmap items
M1 blackboard triggers - Hearsay-II [F]	router dispatches by typed triggers; test_router_dispatches_by_trigger	keep; no new work
M2 typed contracts - MAST [F]	contract validation; test_contract_violation_refused	keep
M3 ledgers + stalls - Magentic-One [F]	board as task ledger; stall counters	G9 (ledger feeds metrics)
M4 spawn with isolation - Anthropic [F]	exploit/statefuzz_spec provenance; depth limit	keep
M5 per-phase recruitment - AgentVerse [F]	trigger-gated activation	keep
M6 verify-before-learn - Voyager [F]	refuted findings penalize techniques	G8 (independence)

Verdict (source)	Executed evidence in this repo	Roadmap items
M7 insight curation - ExpeL [F]	per-specialist namespaces	G5 (scoping)
M8 minimal skill surface - BFCL / Anthropic [F]	one-tool specialists	keep
E1 bandit loop - ExpeL / Voyager [F]	run 2 leaner (188 to 181; 329 to 322)	G5 (persistence policy)
E2 GEPA deferral [F]	strategy objects swappable today	Phase H, G9
E3 grounded reflection - Huang [F]	verify re-executes with fresh principals	G8
E4 outcome weights	refuted adds to beta; no reward	keep; enforced in H
E5 sleep-time consolidation [F]	end-of-run curate()	G5
E6 no self-confidence routing - Tian [H]	evidence-based routing; seam contract	G4, M7
R1 openapi dependence is the weakness	fortress baseline 0/10; U1-U3 upgrades	G1, M2
R2 Kettle race methodology [F]	race_multi last-byte sync	G7, M8
R5 loopback validity threat	app-side widened windows, honest notes	G7
A1-A3 anti-patterns	poisoning guard; insight gate	Chapter 6 (rejected)

Table 5 - Research verdict to evidence to roadmap item.

8. Metrics and Reporting Contract

A phase is not done until its numbers are computed from artifacts by the scorer (G9), not asserted. Six metrics make "done" checkable.

- **Discovery rate** - seeds hit over total, scored against ground truth consulted only after all runs finish.
- **False-positive rate** - findings mapped to decoys over total findings; every lab ships decoys from now on (the MAST verification-failure probe).
- **Cost** - requests per verified finding, and wall-clock per run.
- **Ledger score** - confirmed 1.0, confirmed-by-transcript 0.5, refuted 1.0, inconclusive 0. A refuted belief scores as high as a confirmed one: refuting a hypothesis with evidence is a result, not a failure.
- **Learning delta** - same-target: requests in run n+1 versus run n at equal discovery; cross-target: hit-rate on a fresh target with versus without the global insight store.
- **Verification independence** - share of findings re-verified by the out-of-process prover; target at least 90 percent.

The reporting contract for every future run: findings.json and traffic.jsonl with provenance stamps, hypothesis_ledger.json with the full believe-test-resolve lifecycle, and a report with an explicit misses section - the found/missed matrix against ground truth, false positives against decoys, and the honest gaps the run exposed. This is the format every report since fortress has used; the roadmap holds itself to it.